



CyberScan
Security Audit Platform

RAPPORT D'AUDIT DE SÉCURITÉ

CyberScan — Plateforme d'analyse automatisée

Domaine : esprit.com

Date : 17/07/2026 16:15

FAIBLE

Sécurité 8.1/10 — Risque IA 1.9000000000000001/10

Document confidentiel — Usage interne uniquement

Sommaire

1. Informations générales
2. Résumé exécutif
3. Outils utilisés
4. Résultats du scan
5. Technologies détectées
6. Vulnérabilités
7. CVE et scores CVSS
8. Recommandations IA
9. Plan de correction
10. Conclusion

Rapport d'audit de sécurité

CyberScan — Analyse automatisée multi-outils

■ Informations générales

Domaine analysé	esprit.com
Date du scan	17/07/2026 16:15
Score global de sécurité	8.1/10
Score de risque IA	1.9000000000000001/10
Niveau de risque	Faible
Identifiant scan	56

NIVEAU DE RISQUE : FAIBLE | Sécurité 8.1/10 | Risque IA 1.9000000000000001/10

■ Résumé exécutif

Ce rapport présente les résultats de l'audit de sécurité automatisé réalisé par CyberScan sur le domaine « esprit.com » le 17/07/2026 à 16:15 (UTC). Le score global de sécurité est estimé à 8.1/10, correspondant à un niveau de risque « Faible » (score de risque IA : 1.9000000000000001/10). Synthèse : 40 CVE référencée(s), 0 indicateur(s) SSL/TLS, 2 protocole(s) détecté(s), 12 technologie(s) web, 13 alerte(s) OWASP ZAP, 40 résultat(s) NVD. Le profil de risque global est relativement faible. Maintenez les bonnes pratiques et un suivi régulier des mises à jour.

■ Outils utilisés

- SSLScan
- OpenSSL
- Nmap
- WhatWeb
- OWASP ZAP Baseline
- NVD API

■ Résultats du scan — synthèse

Les sections suivantes détaillent les sorties brutes de chaque outil exécuté lors de l'audit automatisé.

■ Technologies détectées

- Country (UNITED STATES)
- Email (privacy@esprit.com)
- Google-Analytics (v=Universal)
- HTML5
- HTTPServer (Netlify)
- IP (75.2.60.5)
- Meta-Author (Esprit)
- Open-Graph-Protocol (v=website)

- Script (module)
- Strict-Transport-Security (max-age=31536000)
- Title (ESPRIT - Coming Soon)
- UncommonHeaders (cache-status,x-nf-request-id)

■ Vulnérabilités

- [Medium] Content Security Policy (CSP) Header Not Set – <https://esprit.com>
- [Medium] Missing Anti-clickjacking Header – <https://esprit.com>
- [Medium] Sub Resource Integrity Attribute Missing – <https://esprit.com>
- [Low] Cross-Domain JavaScript Source File Inclusion – <https://esprit.com>
- [Low] Cross-Origin-Embedder-Policy Header Missing or Invalid – <https://esprit.com>
- [Low] Cross-Origin-Opener-Policy Header Missing or Invalid – <https://esprit.com>
- [Low] Cross-Origin-Resource-Policy Header Missing or Invalid – <https://esprit.com>
- [Low] Permissions Policy Header Not Set – <https://esprit.com>
- [Low] X-Content-Type-Options Header Missing – <https://esprit.com>
- [Informational] Modern Web Application – <https://esprit.com>
- [Informational] Re-examine Cache-control Directives – <https://esprit.com>
- [Informational] Retrieved from Cache – <https://esprit.com>
- [Informational] Storable and Cacheable Content – <https://esprit.com>

■ Résultats SSLScan

Protocoles : TLSv1.2, TLSv1.3. Vulnérabilités SSL : aucune.

```
Version: [32m2.1.5[0m
OpenSSL 3.5.6 7 Apr 2026
[0m
[32mConnected to 75.2.60.5[0m

Testing SSL server [32mesprit.com[0m on port [32m443[0m using SNI name [32mesprit.com[0m

[1;34mSSL/TLS Protocols:[0m
SSLv2 [32mdisabled[0m
SSLv3 [32mdisabled[0m
TLSv1.0 [32mdisabled[0m
TLSv1.1 [32mdisabled[0m
TLSv1.2 enabled
TLSv1.3 [32menabled[0m

[1;34mTLS Fallback SCSV:[0m
Server [32msupports[0m TLS Fallback SCSV

[1;34mTLS renegotiation:[0m
Session renegotiation [32mnot supported[0m

[1;34mTLS Compression:[0m
Compression [32mdisabled[0m

[1;34mHeartbleed:[0m
TLSv1.3 [32mnot vulnerable[0m to heartbleed
TLSv1.2 [32mnot vulnerable[0m to heartbleed

[1;34mSupported Server Cipher(s):[0m
[32mPreferred[0m [32mTLSv1.3[0m [32m128[0m bits [32mTLS_AES_128_GCM_SHA256 [0m Curve
[32m25519[0m DHE 253
Accepted [32mTLSv1.3[0m [32m256[0m bits [32mTLS_AES_256_GCM_SHA384 [0m Curve [32m25519[0m DHE 253
Accepted [32mTLSv1.3[0m [32m256[0m bits [32mTLS_CHACHA20_POLY1305_SHA256 [0m Curve [32m25519[0m DHE
253
[32mPreferred[0m TLSv1.2 [32m128[0m bits [32mECDHE-ECDSA-AES128-GCM-SHA256[0m Curve [32m25519[0m
DHE 253
Accepted TLSv1.2 [32m256[0m bits [32mECDHE-ECDSA-AES256-GCM-SHA384[0m Curve [32m25519[0m DHE 253
Accepted TLSv1.2 [32m256[0m bits [32mECDHE-ECDSA-CHACHA20-POLY1305[0m Curve [32m25519[0m DHE 253

[1;34mServer Key Exchange Group(s):[0m
TLSv1.3 [32m128[0m bits secp256r1 (NIST P-256)[0m
TLSv1.3 [32m128[0m bits [32mx25519[0m
TLSv1.2 [32m128[0m bits secp256r1 (NIST P-256)[0m

TLSv1.2 [32m128[0m bits [32mx25519[0m

[1;34mSSL Certificate:[0m
```

Signature Algorithm: ecdsa-with-SHA384
ECC Curve Name: prime256v1
ECC Key Strength: 128[0m

Subject: esprit.com
AltNames: DNS:esprit.com, DNS:www.esprit.com
Issuer: E7

Not valid before: [32mMay 21 13:53:53 2026 GMT[0m
Not valid after: [32mAug 19 13:53:52 2026 GMT[0m

■ Résultats OpenSSL

```
Connecting to 75.2.60.5
depth=2 C=US, O=Internet Security Research Group, CN=ISRG Root X1
verify return:1
depth=1 C=US, O=Let's Encrypt, CN=E7
verify return:1
depth=0 CN=esprit.com
verify return:1
CONNECTED(00000003)
---
Certificate chain
0 s:CN=esprit.com
i:C=US, O=Let's Encrypt, CN=E7
a:PKEY: EC, (prime256v1); sigalg: ecdsa-with-SHA384
v:NotBefore: May 21 13:53:53 2026 GMT; NotAfter: Aug 19 13:53:52 2026 GMT
1 s:C=US, O=Let's Encrypt, CN=E7
i:C=US, O=Internet Security Research Group, CN=ISRG Root X1
a:PKEY: EC, (secp384r1); sigalg: sha256WithRSAEncryption
v:NotBefore: Mar 13 00:00:00 2024 GMT; NotAfter: Mar 12 23:59:59 2027 GMT
---
Server certificate
-----BEGIN CERTIFICATE-----
MIIDjzCCAxxwAwIBAgISBeGxVr973fU0JcBgfaWUyXMAoGCCqGSM49BAMDMDIx
CzAJBgNVBAYTALVTMRyWfAYDVQKEw1MZXQncyBFbmNyeXB0MQswCQYDVQDEwJF
NzAeFw0yNjA1MjExMzUzNTNaFw0yNjA4MTkxMzUzNTJAMBUXEzARBgNVBAMTCmVz
cHJpdC5jb20wWTATBgqhkhjOPQIBBgqhkhjOPQMBBwNCAASI2AJKLzHBntW2WWNG
dMAi4Hzs9H02a4VVbSTYN6piulnb7Lg81s0oHu0x6LusZXuGXC5fhRaPl5Ejx/aK
4TBf04ICJjCCAIiWdgYDVR0PAQH/BAQDAgeAMBMGA1UdJQQMMAoGCCsGAQUFBwMB
MAwGA1UdEwEB/wQCMAAwHQYDVIR00BBYEFJ/k7jZvGa338Es+DHF2eBJwQlI4MB8G
A1UdIwQYMBaAFK5IntyHHUSgb9qi5WB0BHjCnACAMDIGCCsGAQUFBwEBBCYwJDAi
BggrBgEFBQcwAoYwahr0cDovL2U3LmkuYVUyY3Iub3JnLzAlBgNVHREEHjAcggpl
c3ByaXQuY29tgg53d3cuZXNwcm10LmNvbTATBgNVHSAEDDAKMAGBmeBDAECATAt
BgNVHR8EJjAkMCKgIKAehhxodHRwOi8vZTcuYy5sZW5jci5vcmcvMjQuY3J3MIIB
DAYKKwYBBAHwEIEAgSB/QSB+gD4AHYAwJF+V0Uzo0XufzjespBB68fCIVoiv3/V
ta12mtk0Us0AAAGeSwX4LAAABAMARzBFAiBZj4+xyH043XaN7hzyCSMQP7mv0mFr
iaVCfCv3zdCCGwIhANj9S8GHsX5y1K0wLFsu39LRzzh4qks0XpNiCNUtovHKAH4A
bP5QG0U0oXqkwwFLRM+TcyR7xQRx9JYQg0X0AnhgY6zoAAAGeSwX47wAIAAAFAAyc
7q8EAWBHMEUCIGneg3GVpAMC1a24cY08ZLqAZ20xAR/y7XKk/2dMzhNAiEAqPLj
yaES4t2Ijf26IHZ1+6iv1o/IA4sFgjKSGvfPZOUwCgYIKoZIZj0EAWMDaAAWZQIX
AImTt5Gc9133NqfynQrL5Le80F1UjMFPetgIo6uycYZS0zjTqe72+X2iRDL7nUsm
nQIwCjAh6pI9vvQlkX7fPjo35cfBRA+zEMsmtzf0Sx51Cf+m9UC9PwMSnYrCBUG
-----END CERTIFICATE-----
subject=CN=esprit.com
issuer=C=US, O=Let's Encrypt, CN=E7
---
No client certificate CA names sent
Peer signing digest: SHA256
Peer signature type: ecdsa_secp256r1_sha256
Peer Temp Key: X25519, 253 bits
---
SSL handshake has read 2395 bytes and written 1616 bytes
Verification: OK
---
New, TLSv1.3, Cipher is TLS_AES_128_GCM_SHA256
Protocol: TLSv1.3
Server public key is 256 bit
This TLS version forbids renegotiation.
Compression: NONE
Expansion: NONE
```

```

No ALPN negotiated
Early data was not sent
Verify return code: 0 (ok)
---
DONE
---
Post-Handshake New Session Ticket arrived:
SSL-Session:
Protocol : TLSv1.3
Cipher : TLS_AES_128_GCM_SHA256
Session-ID: B0528ED05501A23E00DB86359144902E0E88DDE41DE00425D133E8DFB0C024EC
Session-ID-ctx:
Resumption PSK: 7187F47B3CEB6BE435F58DBC7BFEDFD91302CBBA5160F0217DFA58FCCBF09E7
PSK identity: None
PSK identity hint: None
SRP username: None
TLS session ticket lifetime hint: 604800 (seconds)
TLS session ticket:
0000 - 82 f5 a2 d9 53 9e 57 ac-2c 39 54 1b 39 73 1e 01 ...S.W.,9T.9s..
0010 - b0 77 09 44 a2 a0 0d 53-63 73 1d b9 c0 89 ae 59 .w.D...Scs....Y
0020 - 70 e4 83 d5 8e ad 04 01-2a 56 20 53 7f ab 12 9f p.....*V S....

0030 - 8c 83 fc 61 de be 7f 27-ad a5 96 3f 12 5d 34 b3 ...a...'...?]4.
0040 - 31 a7 ac 51 74 2b 53 ef-33 7b c2 33 ea 30 60 68 1..Qt+S.3{.3.0`h
0050 - d4 09 d3 27 14 2f d3 49-eb 58 f0 82 fb 23 85 b0 ...'./.I.X...#..
0060 - b9 aa 28 ce 32 28 71 9c-06 ..

[... sortie tronquée pour lisibilité du rapport ...]

```

■ Résultats Nmap

```

Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-17 17:03 CET
Nmap scan report for esprit.com (75.2.60.5)
Host is up (0.054s latency).
rDNS record for 75.2.60.5: acd89244c803f7181.awsglobalaccelerator.com

PORT STATE SERVICE
443/tcp open https
| ssl-enum-ciphers:
| TLSv1.2:
| ciphers:
| TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256 (secp256r1) - A
| TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384 (secp256r1) - A
| TLS_ECDHE_ECDSA_WITH_CHACHA20_POLY1305_SHA256 (secp256r1) - A
| compressors:
| NULL
| cipher preference: client
| TLSv1.3:
| ciphers:
| TLS_AKE_WITH_AES_128_GCM_SHA256 (ecdh_x25519) - A
| TLS_AKE_WITH_AES_256_GCM_SHA384 (ecdh_x25519) - A
| TLS_AKE_WITH_CHACHA20_POLY1305_SHA256 (ecdh_x25519) - A
| cipher preference: server
|_ least strength: A

Nmap done: 1 IP address (1 host up) scanned in 2.27 seconds

```

■ Résultats WhatWeb

- Country (UNITED STATES)
- Email (privacy@esprit.com)
- Google-Analytics (v=Universal)
- HTML5
- HTTPServer (Netlify)
- IP (75.2.60.5)
- Meta-Author (Esprit)
- Open-Graph-Protocol (v=website)
- Script (module)
- Strict-Transport-Security (max-age=31536000)
- Title (ESPRIT - Coming Soon)
- UncommonHeaders (cache-status,x-nf-request-id)

■ Résultats OWASP ZAP

```
• [Medium] Content Security Policy (CSP) Header Not Set – https://esprit.com (x4)
Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types
of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for
everything from data theft to site defacement or distribution of malware. CSP provides a
• [Medium] Missing Anti-clickjacking Header – https://esprit.com (x2)
The response does not protect against 'ClickJacking' attacks. It should include either
Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
• [Medium] Sub Resource Integrity Attribute Missing – https://esprit.com (x4)
The integrity attribute is missing on a script or link tag served by an external server. The integrity tag
prevents an attacker who have gained access to this server from injecting a malicious content.
• [Low] Cross-Domain JavaScript Source File Inclusion – https://esprit.com (x4)
The page includes one or more script files from a third-party domain.
• [Low] Cross-Origin-Embedder-Policy Header Missing or Invalid – https://esprit.com (x2)
Cross-Origin-Embedder-Policy header is a response header that prevents a document from loading any
cross-origin resources that don't explicitly grant the document permission (using CORP or CORS).
• [Low] Cross-Origin-Opener-Policy Header Missing or Invalid – https://esprit.com (x2)
Cross-Origin-Opener-Policy header is a response header that allows a site to control if others included
documents share the same browsing context. Sharing the same browsing context with untrusted documents might
lead to data leak.
• [Low] Cross-Origin-Resource-Policy Header Missing or Invalid – https://esprit.com (x5)
Cross-Origin-Resource-Policy header is an opt-in header designed to counter side-channels attacks like
Spectre. Resource should be specifically set as shareable amongst different origins.
• [Low] Permissions Policy Header Not Set – https://esprit.com (x5)
Permissions Policy Header is an added layer of security that helps to restrict from unauthorized access or
usage of browser/client features by web resources. This policy ensures the user privacy by limiting or
specifying the features of the browsers can be used by the web resources. Permissions Poli
• [Low] X-Content-Type-Options Header Missing – https://esprit.com (x5)
The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of
Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response
body to be interpreted and displayed as a content type other than the declared con
• [Informational] Modern Web Application – https://esprit.com (x2)
The application appears to be a modern web application. If you need to explore it automatically then the
Client Spider may well be more effective than the standard one.
• [Informational] Re-examine Cache-control Directives – https://esprit.com (x3)
The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache
content. For static assets like css, js, or image files this might be intended, however, the resources should
be reviewed to ensure that no sensitive content will be cached.
• [Informational] Retrieved from Cache – https://esprit.com (x5)
The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific,
this may result in sensitive inform

[... sortie tronquée pour lisibilité du rapport ...]
```

■ Résultats SSL Labs API

```
SSL Labs non inclus dans ce scan. Les résultats SSL Labs apparaîtront ici lorsqu'ils seront présents dans
resultats_ssl["ssllabs"].
```

■ Résultats NVD API

```
Statut NVD : Erreur
Nombre de CVE NVD : 40
Erreurs : Limite NVD publique atteinte; configurez NVD_API_KEY pour rechercher les autres technologies.
• CVE-2003-1268 – CVSS 7.5 (HIGH) – Multiple SQL injection vulnerabilities in (1) addcustomer.asp, (2)
addprod.asp, and (3) process.asp in a.shopKart 2.0.3 allow remote attackers to execute arbitrary SQL and
obtain sensitive information
• CVE-2004-1926 – CVSS 7.5 (HIGH) – Tiki CMS/Groupware (TikiWiki) 1.8.1 and earlier allows remote attackers
to inject arbitrary code via the (1) Theme, (2) Country, (3) Real Name, or (4) Displayed time zone fields in
a User Profile, or
• CVE-2004-0866 – CVSS 7.5 (HIGH) – Internet Explorer 6.0 allows web sites to set cookies for
country-specific top-level domains, such as .ltd.uk, .plc.uk, and .sch.uk, which could allow remote attackers
to perform a session fixation at
• CVE-2004-0746 – CVSS 7.5 (HIGH) – Konqueror in KDE 3.2.3 and earlier allows web sites to set cookies for
country-specific top-level domains, such as .ltd.uk, .plc.uk and .firm.in, which could allow remote attackers
to perform a sessio
• CVE-2004-0867 – CVSS 7.5 (HIGH) – Mozilla Firefox 0.9.2 allows web sites to set cookies for
country-specific top-level domains, such as .ltd.uk, .plc.uk, and .sch.uk, which could allow remote attackers
to perform a session fixation at
• CVE-2004-2180 – CVSS 4.3 (MEDIUM) – Multiple cross-site scripting (XSS) vulnerabilities in WowBB Forum 1.61
allow remote attackers to inject arbitrary web script or HTML via the (1) country parameter to view_user.php,
```

(2) show parameter

- CVE-2004-2511 – CVSS 4.3 (MEDIUM) – Multiple cross-site scripting (XSS) vulnerabilities in DCP-Portal 5.3.2 and earlier allow remote attackers to inject arbitrary web script or HTML via (1) the year, (2) month, and (3) day parameters in
- CVE-2005-0995 – CVSS 4.3 (MEDIUM) – Multiple cross-site scripting (XSS) vulnerabilities in ProductCart 2.7 allow remote attackers to inject arbitrary web script or HTML via (1) the keyword parameter to advSearch_h.asp, (2) the redirectU
- CVE-2005-2985 – CVSS 7.5 (HIGH) – SQL injection vulnerability in search_result.php in AEwebworks aeDating Script 4.0 and earlier allows remote attackers to execute arbitrary SQL statements via the Country parameter.
- CVE-2005-4576 – CVSS 4.3 (MEDIUM) – Multiple cross-site scripting (XSS) vulnerabilities in the UpdateEngine program in Fatwire UpdateEngine 6.2 and earlier allow remote attackers to inject arbitrary web script or HTML via the (1) COUNTR
- CVE-1999-0004 – CVSS 5.0 (MEDIUM) – MIME buffer overflow in email clients, e.g. Solaris mailtool and Outlook.
- CVE-1999-1153 – CVSS 7.5 (HIGH) – HAMcards Postcard CGI script 1.0 allows remote attackers to execute arbitrary commands via shell metacharacters in the recipient email address.
- CVE-1999-1154 – CVSS 7.5 (HIGH) – LakeWeb Filemail CGI script allows remote attackers to execute arbitrary commands via shell metacharacters in the recipient email address.
- CVE-1999-1155 – CVSS 7.5 (HIGH) – LakeWeb Mail List CGI script allows remote attackers to execute arbitrary commands via shell metacharacters in the recipient email address.
- CVE-1999-1323 – CVSS 4.6 (MEDIUM) – Norton AntiVirus for Internet Email Gateways (NAVIEG) 1.0.1.7 and earlier, and Norton AntiVirus for MS Exchange (NAVMSX) 1.5 and earlier, store the administrator password in cleartext in (1) the navie
- CVE-1999-1164 – CVSS 5.0 (MEDIUM) – Microsoft Outlook client allows remote attackers to cause a denial of serv

[... sortie tronquée pour lisibilité du rapport ...]

■ Liste des CVE et scores CVSS

CVE-2003-1268	7.5	Multiple SQL injection vulnerabilities in (1) addcustomer.asp, (2) addprod.asp, and (3) process.asp in a.shopKart 2.0.3 allow remote attackers to execute arbitrary SQL and obtain sensitive information via the zip, state, country, phone, and fax parameters.
CVE-2004-1926	7.5	Tiki CMS/Groupware (TikiWiki) 1.8.1 and earlier allows remote attackers to inject arbitrary code via the (1) Theme, (2) Country, (3) Real Name, or (4) Displayed time zone fields in a User Profile, or the (5) Name, (6) Description, (7) URL, or (8) Country fields in a Directory/Add Site operation.
CVE-2004-0866	7.5	Internet Explorer 6.0 allows web sites to set cookies for country-specific top-level domains, such as .ltd.uk, .plc.uk, and .sch.uk, which could allow remote attackers to perform a session fixation attack and hijack a user's HTTP session.
CVE-2004-0746	7.5	Konqueror in KDE 3.2.3 and earlier allows web sites to set cookies for country-specific top-level domains, such as .ltd.uk, .plc.uk and .firm.in, which could allow remote attackers to perform a session fixation attack and hijack a user's HTTP session.
CVE-2004-0867	7.5	Mozilla Firefox 0.9.2 allows web sites to set cookies for country-specific top-level domains, such as .ltd.uk, .plc.uk, and .sch.uk, which could allow remote attackers to perform a session fixation attack and hijack a user's HTTP session. NOTE: it was later reported that 2.x is also affected.
CVE-2004-2180	4.3	Multiple cross-site scripting (XSS) vulnerabilities in WowBB Forum 1.61 allow remote attackers to inject arbitrary web script or HTML via the (1) country parameter to view_user.php, (2) show parameter to view_forum.php, (3) letter parameter to view_user.php, (4) highlight parameter to view_topic.php, (5) show parameter to index.php, (6) q parameter to search.php, (7) Referer header to admin.php, o
CVE-2004-2511	4.3	Multiple cross-site scripting (XSS) vulnerabilities in DCP-Portal 5.3.2 and earlier allow remote attackers to inject arbitrary web script or HTML via (1) the year, (2) month, and (3) day parameters in calendar.php; (4) the cid and (5) url parameters in index.php; (6) the cid parameter in annoucement.php; (7) the cid parameter in news.php; (8) the cid parameter in contents.php; (9) the q parameter

CVE-2005-0995	4.3	Multiple cross-site scripting (XSS) vulnerabilities in ProductCart 2.7 allow remote attackers to inject arbitrary web script or HTML via (1) the keyword parameter to advSearch_h.asp, (2) the redirectUrl parameter to NewCust.asp, (3) the country parameter to storelocator_submit.asp, or (4) the error parameter to techErr.asp. NOTE: it has been reported that storelocator_submit.asp does not exist in
CVE-2005-2985	7.5	SQL injection vulnerability in search_result.php in AEwebworks aeDating Script 4.0 and earlier allows remote attackers to execute arbitrary SQL statements via the Country parameter.
CVE-2005-4576	4.3	Multiple cross-site scripting (XSS) vulnerabilities in the UpdateEngine program in Fatwire UpdateEngine 6.2 and earlier allow remote attackers to inject arbitrary web script or HTML via the (1) COUNTRYNAME, (2) EMAIL, and (3) FUELAP_TEMPLATENAME parameters.
CVE-1999-0004	5.0	MIME buffer overflow in email clients, e.g. Solaris mailtool and Outlook.
CVE-1999-1153	7.5	HAMcards Postcard CGI script 1.0 allows remote attackers to execute arbitrary commands via shell metacharacters in the recipient email address.
CVE-1999-1154	7.5	LakeWeb Filemail CGI script allows remote attackers to execute arbitrary commands via shell metacharacters in the recipient email address.
CVE-1999-1155	7.5	LakeWeb Mail List CGI script allows remote attackers to execute arbitrary commands via shell metacharacters in the recipient email address.
CVE-1999-1323	4.6	Norton AntiVirus for Internet Email Gateways (NAVIEG) 1.0.1.7 and earlier, and Norton AntiVirus for MS Exchange (NAV MSE) 1.5 and earlier, store the administrator password in cleartext in (1) the navieg.ini file for NAVIEG, and (2) the ModifyPassword registry key in NAV MSE.
CVE-1999-1164	5.0	Microsoft Outlook client allows remote attackers to cause a denial of service by sending multiple email messages with the same X-UIDL headers, which causes Outlook to hang.
CVE-1999-0682	5.0	Microsoft Exchange 5.5 allows a remote attacker to relay email (i.e. spam) using encapsulated SMTP addresses, even if the anti-relaying features are enabled.
CVE-1999-1016	5.0	Microsoft HTML control as used in (1) Internet Explorer 5.0, (2) FrontPage Express, (3) Outlook Express 5, and (4) Eudora, and possibly others, allows remote malicious web site or HTML emails to cause a denial of service (100% CPU consumption) via large HTML form fields such as text inputs in a table cell.
CVE-1999-0354	7.5	Internet Explorer 4.x or 5.x with Word 97 allows arbitrary execution of Visual Basic programs to the IE client through the Word 97 template, which doesn't warn the user that the template contains executable content. Also applies to Outlook when the client views a malicious email message.
CVE-1999-1190	10.0	Buffer overflow in POP3 server of Admiral Systems EmailClub 1.05 allows remote attackers to execute arbitrary commands via a long "From" header in an e-mail message.
CVE-2010-1664	5.0	Google Chrome before 4.1.249.1064 does not properly handle HTML5 media, which allows remote attackers to cause a denial of service (memory corruption) and possibly have unspecified other impact via unknown vectors.
CVE-2010-3019	9.3	Heap-based buffer overflow in Opera before 10.61 allows remote attackers to execute arbitrary code or cause a denial of service (application crash or hang) via vectors related to HTML5 canvas painting operations that occur during the application of transformations.
CVE-2010-4046	4.3	Opera before 10.63 does not properly verify the origin of video content, which allows remote attackers to obtain sensitive information by using a video stream as HTML5 canvas content.
CVE-2010-4484	5.0	Google Chrome before 8.0.552.215 does not properly handle HTML5 databases, which allows attackers to cause a denial of service (application crash) via unspecified vectors.

CVE-2011-0166	5.8	The HTML5 drag and drop functionality in WebKit in Apple Safari before 5.0.4 allows user-assisted remote attackers to bypass the Same Origin Policy and obtain sensitive information via vectors related to the dragging of content. NOTE: this might overlap CVE-2011-0778.
CVE-2011-3389	4.3	The SSL protocol, as used in certain configurations in Microsoft Windows and Microsoft Internet Explorer, Mozilla Firefox, Google Chrome, Opera, and other products, encrypts data by using CBC mode with chained initialization vectors, which allows man-in-the-middle attackers to obtain plaintext HTTP headers via a blockwise chosen-boundary attack (BCBA) on an HTTPS session, in conjunction with JavaS
CVE-2012-0445	5.0	Mozilla Firefox 4.x through 9.0, Thunderbird 5.0 through 9.0, and SeaMonkey before 2.7 allow remote attackers to bypass the HTML5 frame-navigation policy and replace arbitrary sub-frames by creating a form submission target with a sub-frame's name attribute.
CVE-2012-3530	4.3	Incomplete blacklist vulnerability in the t3lib_div::quoteJSvalue API function in TYPO3 4.5.x before 4.5.19, 4.6.x before 4.6.12 and 4.7.x before 4.7.4 allows remote attackers to conduct cross-site scripting (XSS) attacks via certain HTML5 JavaScript events.
CVE-2012-3985	4.3	Mozilla Firefox before 16.0, Thunderbird before 16.0, and SeaMonkey before 2.13 do not properly implement the HTML5 Same Origin Policy, which allows remote attackers to conduct cross-site scripting (XSS) attacks by leveraging initial-origin access after document.domain has been set.
CVE-2013-0095	5.0	Outlook in Microsoft Office for Mac 2008 before 12.3.6 and Office for Mac 2011 before 14.3.2 allows remote attackers to trigger access to a remote URL and consequently confirm the rendering of an HTML e-mail message by including unspecified HTML5 elements and leveraging the installation of a WebKit browser on the victim's machine, aka "Unintended Content Loading Vulnerability."
CVE-2007-1939	6.8	Cross-site scripting (XSS) vulnerability in the embedded webserver in Daniel Naber LanguageTool before 0.8.9 allows remote attackers to inject arbitrary web script or HTML via unspecified vectors involving an error message, possibly the demultiplex method in HTTPServer.java.
CVE-2017-7504	9.8	HTTPServerILServlet.java in JMS over HTTP Invocation Layer of the JbossMQ implementation, which is enabled by default in Red Hat Jboss Application Server <= Jboss 4.X does not restrict the classes for which it performs deserialization, which allows remote attackers to execute arbitrary code via crafted serialized data.
CVE-2018-12537	5.3	In Eclipse Vert.x version 3.0 to 3.5.1, the HttpServer response headers and HttpClient request headers do not filter carriage return and line feed characters from the header value. This allow unfiltered values to inject a new header in the client request or server response.
CVE-2019-3888	9.8	A vulnerability was found in Undertow web server before 2.0.21. An information exposure of plain text credentials through log files because Connectors.executeRootHandler:402 logs the HttpServerExchange object at ERROR level using UndertowLogger.REQUEST_LOGGER.undertowRequestFailed(t, exchange)
CVE-2020-5403	7.5	Reactor Netty HttpServer, versions 0.9.3 and 0.9.4, is exposed to a URISyntaxException that causes the connection to be closed prematurely instead of producing a 400 response.
CVE-2022-35252	3.7	When curl is used to retrieve and parse cookies from a HTTP(S) server, itaccepts cookies using control codes that when later are sent back to a HTTPserver might make the server return 400 responses. Effectively allowing a"sister site" to deny service to all siblings.

CVE-2019-25087	5.3	A vulnerability was found in RamseyK httpserver. It has been rated as critical. This issue affects the function ResourceHost::getResource of the file src/ResourceHost.cpp of the component URI Handler. The manipulation of the argument uri leads to path traversal: './filedir'. The attack may be initiated remotely. The name of the patch is 1a0de56e4daff9c2f9c8f6b130a764f7a50df52. It is recommended
CVE-2026-35392	9.8	goshs is a SimpleHTTPServer written in Go. Prior to 2.0.0-beta.3, PUT upload in httpserver/updown.go has no path sanitization. This vulnerability is fixed in 2.0.0-beta.3.
CVE-2026-44895	0.0	GitLab MCP Server lets an AI agent talk directly to GitLab. Prior to 0.6.0, the HTTP transport in src/transport.ts ships with no authentication layer at all and a wildcard Access-Control-Allow-Origin: * on every response. The structural defect is that the SSE server stands up a stateful, mutation-capable RPC endpoint that is backed by the operator's GITLAB_PERSONAL_ACCESS_TOKEN without any inbound
CVE-2026-49855	7.5	Tornado is a Python web framework and asynchronous networking library. Prior to 6.5.6, Tornado gzip decompression routines processed limited-size chunks but did not enforce an overall limit on accumulated decompressed chunks, allowing a malicious server accessed by SimpleAsyncHTTPClient or an HTTPServer configured with decompress_request=True to consume effectively unlimited memory. This issue is

Score CVSS moyen : 6.1/10 — Nombre de CVE : 40

■ Recommendations IA

1. [CVE-2022-35252] to deny service to all siblings.
2. [ZAP — Content Security Policy (CSP) Header Not Set] Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
3. [ZAP — Missing Anti-clickjacking Header] Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
4. [ZAP — Sub Resource Integrity Attribute Missing] Provide a valid integrity attribute to the tag.
5. [ZAP — Cross-Domain JavaScript Source File Inclusion] Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application.
6. [ZAP — Cross-Origin-Embedder-Policy Header Missing or Invalid] Ensure that the application/web server sets the Cross-Origin-Embedder-Policy header appropriately, and that it sets the Cross-Origin-Embedder-Policy header to 'require-corp' for documents. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Embedder-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-embedder-policy).
7. [ZAP — Cross-Origin-Opener-Policy Header Missing or Invalid] Ensure that the application/web server sets the Cross-Origin-Opener-Policy header appropriately, and that it sets the Cross-Origin-Opener-Policy header to 'same-origin' for documents. 'same-origin-allow-popups' is considered as less secured and should be avoided. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Opener-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-opener-policy).
8. [ZAP — Cross-Origin-Resource-Policy Header Missing or Invalid] Ensure that the application/web server sets the Cross-Origin-Resource-Policy header appropriately, and that it sets the Cross-Origin-Resource-Policy header to 'same-origin' for all web pages. 'same-site' is considered as less secured and should be avoided. If resources must be shared, set the header to 'cross-origin'. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Resource-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-resource-policy).
9. [ZAP — Permissions Policy Header Not Set] Ensure that your web server, application server, load balancer, etc. is configured to set the Permissions-Policy header.
10. [ZAP — X-Content-Type-Options Header Missing] Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible,

ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.

11. [ZAP — Modern Web Application] This is an informational alert and so no changes are required.

12. [ZAP — Re-examine Cache-control Directives] For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".

13. [ZAP — Retrieved from Cache] Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.

■ Plan de correction

Immédiate (P1)	CVE-1999-1190	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2019-3888	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2017-7504	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2026-35392	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2010-3019	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2005-2985	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-1999-1153	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-1999-1154	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-1999-1155	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2003-1268	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2004-1926	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2004-0866	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2004-0746	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2004-0867	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-1999-0354	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2020-5403	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2026-49855	Appliquer le correctif selon l'avis NVD.
Court terme (P2)	CVE-2007-1939	Appliquer le correctif selon l'avis NVD.
Court terme (P2)	CVE-2011-0166	Appliquer le correctif selon l'avis NVD.
Court terme (P2)	CVE-2018-12537	Appliquer le correctif selon l'avis NVD.
Court terme (P2)	CVE-2019-25087	Appliquer le correctif selon l'avis NVD.
Court terme (P2)	CVE-1999-1016	Appliquer le correctif selon l'avis NVD.
Court terme (P2)	CVE-1999-0004	Appliquer le correctif selon l'avis NVD.
Court terme (P2)	CVE-2010-1664	Appliquer le correctif selon l'avis NVD.
Court terme (P2)	CVE-2010-4484	Appliquer le correctif selon l'avis NVD.
Court terme (P2)	CVE-2012-0445	Appliquer le correctif selon l'avis NVD.

Court terme (P2)	CVE-2013-0095	Appliquer le correctif selon l'avis NVD.
Court terme (P2)	CVE-1999-1164	Appliquer le correctif selon l'avis NVD.
Court terme (P2)	CVE-1999-0682	Appliquer le correctif selon l'avis NVD.
Court terme (P2)	CVE-1999-1323	Appliquer le correctif selon l'avis NVD.

■ Conclusion

L'audit du domaine esprit.com présente un profil de risque faible (score de sécurité 8.1/10). Maintenez la configuration actuelle, appliquez les correctifs de sécurité et renouvelez les scans régulièrement.

Document généré automatiquement par CyberScan le 17/07/2026 à 16:15 UTC. Usage strictement confidentiel.